Vulnerability Assessment & Penetration Test Report

Assessment ID: asm-86c038739f | Generated: 2026-11-02T01:57:13+00:00 | Opened by: analyst

1. Executive Summary

This assessment covered 1 authorized target(s) and produced 14 correlated finding(s): 2 critical, 2 high, 4 medium, 2 low, 4 info.

Scope: 10.10.10.5

Original request: “Assess the lab web server and host for vulnerabilities ahead of the client demo; flag anything that would need urgent remediation.”

Total correlated findings	14
Priority P1 / P2 / P3 / P4	2 / 5 / 7 / 0
Confirmed / Suspected / Possible false positive	9 / 5 / 0
Actively validated (human-approved)	0
Tools with a successful run	6 (burp, nessus, nikto, nmap, openvas, zap)
Human approval decisions recorded	1

2. Assessment Methodology

This assessment followed a conversational, evidence-driven workflow: analyst request, scope validation, agent-generated and analyst-approved scan plan, scan orchestration, result ingestion, cross-tool correlation, risk prioritization, human-approved active validation where applicable, and report generation. Methodology is informed by NIST SP 800-115, OWASP Top 10, CVE/CVSS/CWE, MITRE ATT&CK, and NIST CSF 2.0, where applicable; using these standards and frameworks does not, by itself, establish formal compliance with them.

Framework alignment (NIST CSF 2.0):

This assessment's own workflow maps to the NIST Cybersecurity Framework (CSF) 2.0 functions as follows: GOVERN -- a registered scope, exclusions, and an auditable, hash-chained decision trail gate every action; IDENTIFY -- host, service, and asset discovery; PROTECT -- evaluating authentication, encryption, and configuration controls; DETECT -- multi-tool correlation and evidence-based finding analysis; RESPOND -- human-approved active validation and remediation guidance. This describes the assessment process itself, not a compliance claim about the target environment.

Rules of engagement:

Authorized targets: 10.10.10.5. Exclusions: none. Active validation permitted: True. Organizer-provided hackathon lab target, ticket #DEMO-001.

Assets actually tested (discovered or referenced by an ingested tool result -- may be narrower than the full authorized scope above):

Asset	Open ports observed	Findings
10.10.10.5	5	14

Tool execution summary:

Tool	Mode	Target	Status	Services	Findings
nessus	import	10.10.10.5	ok	0	1
nmap	import	10.10.10.5	ok	5	10
nikto	import	10.10.10.5	ok	0	3
zap	import	10.10.10.5	ok	0	2

burp	import	10.10.10.5	ok	0	1
openvas	import	10.10.10.5	ok	0	1

3. Severity Distribution and Prioritized Findings

Severity	Critical	High	Medium	Low	Info
Count	2	2	4	2	4

Priority	Severity	Title	Asset	Risk score
P1	critical	MS17-010: SMB RCE	10.10.10.5	80.4
P1	high	SQL injection	10.10.10.5	66.5
P2	critical	CVE-2021-41773 reported against http Apache ht	10.10.10.5	63.6
P2	high	Cross Site Scripting (Reflected)	10.10.10.5	57.8
P2	medium	Anonymous FTP login allowed	10.10.10.5	56.5
P2	medium	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protoc	10.10.10.5	54.5
P2	medium	Weak TLS protocol or cipher configuration	10.10.10.5	54.3
P3	low	Exposed network service: ftp vsftpd 2.3.4 on 2	10.10.10.5	44.9
P3	low	The X-Content-Type-Options header is not set	10.10.10.5	44.8
P3	medium	/cgi-bin/ directory is browsable and may allow	10.10.10.5	41.1
P3	info	Exposed network service: ssh OpenSSH 7.2p2 on	10.10.10.5	34.6
P3	info	Exposed network service: microsoft-ds Samba 3.	10.10.10.5	33.9
P3	info	Exposed network service: http Apache httpd 2.4	10.10.10.5	33.1
P3	info	Exposed network service: https Apache httpd 2.	10.10.10.5	33.1

4. Detailed Vulnerability Findings

[P1] CRITICAL — MS17-010: SMB RCE

Finding ID: raw-d7216fe000 | Asset: 10.10.10.5:445/tcp | Status: confirmed | Validation: approval_pending | Confidence: 0.98

CVSS: 8.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)

References: CVE-2017-0143, CWE-284

MITRE ATT&CK (indicative reference mapping, not an observed adversary action): T1210 — Exploitation of Remote Services

Risk score: 80.4 — cvss=8.1, cvss_estimated=False, confidence=0.98, confidence_factor=0.99, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

The remote host is affected by multiple vulnerabilities in SMBv1.

AI-generated reasoning (not directly observed):

• [inference] Confirmed independently by 2 tools (nessus, nmap); confidence raised accordingly.

• [inference] MITRE ATT&CK reference mapping (indicative, not an adversary action observed during this assessment): T1210 — Exploitation of Remote Services.

Supporting evidence (source tool(s): nessus, nmap):

[nessus | nessus:nessus_sample.nessus#host=10.10.10.5/plugin=97833 | 2026-11-02T01:57:13+00:00 | sha256=7adf0b46f542a75f…]

```
Host is missing MS17-010.
```

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=445/script=smb-vuln-ms17-010 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
VULNERABLE: Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
```

Remediation: Apply the vendor patch (MS17-010). Disable SMBv1.

References: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2017-0143

(Deduplicated: merged 1 overlapping report(s) from nessus, nmap.)

[P1] HIGH — SQL injection

Finding ID: raw-5fc51c9c35 | Asset: 10.10.10.5:80/tcp | Status: suspected | Validation: not_validated | Confidence: 0.90

CVSS: 8.0 (estimated from severity band, not tool-reported)

References: CWE-89, A03:2021-Injection

MITRE ATT&CK (indicative reference mapping, not an observed adversary action): T1190 — Exploit Public-Facing Application

Risk score: 66.5 — cvss=8.0, cvss_estimated=True, confidence=0.9, confidence_factor=0.95, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

SQL injection vulnerabilities arise when user-controllable data is incorporated into SQL queries. The id parameter appears to be vulnerable to SQL injection.

AI-generated reasoning (not directly observed):

• [inference] MITRE ATT&CK reference mapping (indicative, not an adversary action observed during this assessment): T1190 — Exploit Public-Facing Application.

Supporting evidence (source tool(s): burp):

[burp | burp:burp_sample.xml#issue=1 | 2026-11-02T01:57:13+00:00 | sha256=d7edd6255c4740d2…]

```
SQL injection at http://10.10.10.5/product?id=1 (Parameter: id)
```

Remediation: Use parameterized queries for all database access.

[P2] CRITICAL — CVE-2021-41773 reported against http Apache httpd 2.4.49

Finding ID: raw-5f4e09c9bc | Asset: 10.10.10.5:80/tcp | Status: suspected | Validation: not_validated | Confidence: 0.55

CVSS: 9.8

References: CVE-2021-41773, CVE-2021-42013

Risk score: 63.6 — cvss=9.8, cvss_estimated=False, confidence=0.55, confidence_factor=0.78, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

NSE script 'vulners' associated CVE-2021-41773 with the detected service version (http Apache httpd 2.4.49). This is version-based matching; the vulnerable code path was not exercised.

AI-generated reasoning (not directly observed):

• [inference] Version-based match: the vendor may have back-ported a fix.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=80/script=vulners | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
CVE-2021-41773 9.8 (vulners)
```

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=80/script=vulners | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
CVE-2021-42013 9.8 (vulners)
```

(Deduplicated: merged 1 overlapping report(s) from nmap.)

[P2] HIGH — Cross Site Scripting (Reflected)

Finding ID: raw-62d125f9b1 | Asset: 10.10.10.5:80/tcp | Status: suspected | Validation: not_validated | Confidence: 0.65

CVSS: 8.0 (estimated from severity band, not tool-reported)

References: CWE-79, A03:2021-Injection

MITRE ATT&CK (indicative reference mapping, not an observed adversary action): T1190 — Exploit Public-Facing Application

Risk score: 57.8 — cvss=8.0, cvss_estimated=True, confidence=0.65, confidence_factor=0.82, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Reflected XSS allows an attacker to execute script in the context of the victim's browser.

AI-generated reasoning (not directly observed):

• [inference] MITRE ATT&CK reference mapping (indicative, not an adversary action observed during this assessment): T1190 — Exploit Public-Facing Application.

Supporting evidence (source tool(s): zap):

[zap | zap:zap_sample.json#alert=40012/item=0 | 2026-11-02T01:57:13+00:00 | sha256=cbb9d968645b8eff…]

```
GET http://10.10.10.5/search?q=%3Cscript%3Ealert(1)%3C/script%3E param=q
evidence=<script>alert(1)</script>
```

Remediation: Encode all user-controllable output.

References: https://owasp.org/www-community/attacks/xss/

[P2] MEDIUM — Anonymous FTP login allowed

Finding ID: raw-4b169b10ac | Asset: 10.10.10.5:21/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.90

CVSS: 5.5 (estimated from severity band, not tool-reported)

References: CWE-287

MITRE ATT&CK (indicative reference mapping, not an observed adversary action): T1078 — Valid Accounts

Risk score: 56.5 — cvss=5.5, cvss_estimated=True, confidence=0.9, confidence_factor=0.95, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

The FTP server accepts anonymous logins.

AI-generated reasoning (not directly observed):

• [inference] MITRE ATT&CK reference mapping (indicative, not an adversary action observed during this assessment): T1078 — Valid Accounts.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=21/script=ftp-anon | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
Anonymous FTP login allowed (FTP code 230)
```

Remediation: Disable anonymous access unless explicitly required.

[P2] MEDIUM — SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection

Finding ID: raw-5036f1af1e | Asset: 10.10.10.5:443/tcp | Status: suspected | Validation: not_validated | Confidence: 0.80

CVSS: 5.9

Risk score: 54.5 — cvss=5.9, cvss_estimated=False, confidence=0.8, confidence_factor=0.9, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

The remote service accepts connections using TLS 1.0 and/or TLS 1.1.

Supporting evidence (source tool(s): openvas):

[openvas | openvas:openvas_sample.xml#result=r1 | 2026-11-02T01:57:13+00:00 | sha256=933b64957ec993d8…]

```
The remote service accepts connections using TLS 1.0 and/or TLS 1.1.
```

Remediation: Disable TLS 1.0 and 1.1; enable TLS 1.2 or higher.

[P2] MEDIUM — Weak TLS protocol or cipher configuration

Finding ID: raw-da589c5eb6 | Asset: 10.10.10.5:443/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.85

CVSS: 5.5 (estimated from severity band, not tool-reported)

References: CWE-326

Risk score: 54.3 — cvss=5.5, cvss_estimated=True, confidence=0.85, confidence_factor=0.93, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

The server accepts deprecated TLS/SSL protocol versions or weak ciphers.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=443/script=ssl-enum-ciphers | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
TLSv1.0: supported TLSv1.1: supported least strength: D
```

Remediation: Disable SSLv3/TLS1.0/TLS1.1 and weak ciphers; prefer TLS 1.2+ with AEAD suites.

[P3] LOW — Exposed network service: ftp vsftpd 2.3.4 on 21/tcp

Finding ID: raw-1bde68f641 | Asset: 10.10.10.5:21/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.95

CVSS: 2.5 (estimated from severity band, not tool-reported)

References: CWE-319

Risk score: 44.9 — cvss=2.5, cvss_estimated=True, confidence=0.95, confidence_factor=0.97, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Port 21/tcp is open and responded as ftp vsftpd 2.3.4.

AI-generated reasoning (not directly observed):

• [inference] ftp transmits credentials in cleartext (CWE-319); an encrypted alternative should be used.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=21 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
21/tcp open ftp vsftpd 2.3.4
```

[P3] LOW — The X-Content-Type-Options header is not set

Finding ID: raw-46c1dfb32e | Asset: 10.10.10.5:80/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.98

CVSS: 2.5 (estimated from severity band, not tool-reported)

References: CWE-693, A05:2021-Security Misconfiguration

Risk score: 44.8 — cvss=2.5, cvss_estimated=True, confidence=0.98, confidence_factor=0.99, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

The X-Content-Type-Options header is not set. This could allow the user agent to render the content differently from the way it was intended.

AI-generated reasoning (not directly observed):

• [inference] Confirmed independently by 2 tools (nikto, zap); confidence raised accordingly.

Supporting evidence (source tool(s): nikto, zap):

[nikto | nikto:nikto_sample.json#host=10.10.10.5/vuln=0 | 2026-11-02T01:57:13+00:00 | sha256=f2080055f3496f90…]

```
GET /: The X-Content-Type-Options header is not set. This could allow the user agent to
render the content differently from the way it was intended.
```

[nikto | nikto:nikto_sample.json#host=10.10.10.5/vuln=1 | 2026-11-02T01:57:13+00:00 | sha256=f2080055f3496f90…]

```
GET /: The anti-clickjacking X-Frame-Options header is not present.
```

[zap | zap:zap_sample.json#alert=10038/item=1 | 2026-11-02T01:57:13+00:00 | sha256=cbb9d968645b8eff…]

```
GET http://10.10.10.5/ param= evidence=Content Security Policy (CSP) Header Not Set
```

Remediation: Add the missing security response header at the web server or reverse proxy.

References: Nikto test id 1; Nikto test id 2

(Deduplicated: merged 2 overlapping report(s) from nikto, zap.)

[P3] MEDIUM — /cgi-bin/ directory is browsable and may allow unauthorized access to internal scripts

Finding ID: raw-536a1a53e7 | Asset: 10.10.10.5:80/tcp | Status: suspected | Validation: not_validated | Confidence: 0.40

CVSS: 5.5 (estimated from severity band, not tool-reported)

Risk score: 41.1 — cvss=5.5, cvss_estimated=True, confidence=0.4, confidence_factor=0.7, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

/cgi-bin/ directory is browsable and may allow unauthorized access to internal scripts.

Supporting evidence (source tool(s): nikto):

[nikto | nikto:nikto_sample.json#host=10.10.10.5/vuln=2 | 2026-11-02T01:57:13+00:00 | sha256=f2080055f3496f90…]

```
GET /cgi-bin/: /cgi-bin/ directory is browsable and may allow unauthorized access to
internal scripts.
```

References: Nikto test id 3; OSVDB-3092

[P3] INFO — Exposed network service: ssh OpenSSH 7.2p2 on 22/tcp

Finding ID: raw-a74d0e3f54 | Asset: 10.10.10.5:22/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.95

CVSS: 0.0 (estimated from severity band, not tool-reported)

Risk score: 34.6 — cvss=0.0, cvss_estimated=True, confidence=0.95, confidence_factor=0.97, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Port 22/tcp is open and responded as ssh OpenSSH 7.2p2.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=22 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
22/tcp open ssh OpenSSH 7.2p2
```

[P3] INFO — Exposed network service: microsoft-ds Samba 3.0.20 on 445/tcp

Finding ID: raw-fdecd0e3ef | Asset: 10.10.10.5:445/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.95

CVSS: 0.0 (estimated from severity band, not tool-reported)

Risk score: 33.9 — cvss=0.0, cvss_estimated=True, confidence=0.95, confidence_factor=0.97, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Port 445/tcp is open and responded as microsoft-ds Samba 3.0.20.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=445 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
445/tcp open microsoft-ds Samba 3.0.20
```

[P3] INFO — Exposed network service: http Apache httpd 2.4.49 on 80/tcp

Finding ID: raw-1a5a8ab7a8 | Asset: 10.10.10.5:80/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.95

CVSS: 0.0 (estimated from severity band, not tool-reported)

Risk score: 33.1 — cvss=0.0, cvss_estimated=True, confidence=0.95, confidence_factor=0.97, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Port 80/tcp is open and responded as http Apache httpd 2.4.49.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=80 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
80/tcp open http Apache httpd 2.4.49
```

[P3] INFO — Exposed network service: https Apache httpd 2.4.49 on 443/tcp

Finding ID: raw-0720951d82 | Asset: 10.10.10.5:443/tcp | Status: confirmed | Validation: not_validated | Confidence: 0.95

CVSS: 0.0 (estimated from severity band, not tool-reported)

Risk score: 33.1 — cvss=0.0, cvss_estimated=True, confidence=0.95, confidence_factor=0.97, formula=100*(0.45*cvss/10+0.20*expl+0.15*expo+0.20*impact)*(0.5+0.5*confidence)

Port 443/tcp is open and responded as https Apache httpd 2.4.49.

Supporting evidence (source tool(s): nmap):

[nmap | nmap:nmap_sample.xml#host=10.10.10.5/port=443 | 2026-11-02T01:57:13+00:00 | sha256=ea198d2a51ace5e4…]

```
443/tcp open https Apache httpd 2.4.49
```

5. Impact and Remediation Summary

4 finding(s) rated critical/high pose immediate business risk and should be remediated before the system handles production or sensitive data. Each is summarized below with a business and technical impact statement grounded in its own asset criticality, exposure class, and (where the source tool reported one) CVSS vector -- never a generic severity label alone.

MS17-010: SMB RCE (10.10.10.5:445)

Business impact: 10.10.10.5 is treated as high-criticality (set by the analyst) in this assessment's scope. This finding was independently corroborated by 2 tools (nessus, nmap). **Technical impact:** if exploited, this finding could allow unauthorized access to files or shared data on the host, network-exploitable, with high confidentiality, high integrity, high availability impact if successful.

Remediation: Apply the vendor patch (MS17-010). Disable SMBv1.

SQL injection (10.10.10.5:80)

Business impact: 10.10.10.5 is treated as high-criticality (set by the analyst) in this assessment's scope. This finding is currently 'suspected', reported by a single tool (burp), and has not yet been independently corroborated or actively validated. **Technical impact:** if exploited, this finding could allow compromise of the web application, the data it handles, or its users.

Remediation: Use parameterized queries for all database access.

CVE-2021-41773 reported against http Apache httpd 2.4.49 (10.10.10.5:80)

Business impact: 10.10.10.5 is treated as high-criticality (set by the analyst) in this assessment's scope. This finding is currently 'suspected', reported by a single tool (nmap), and has not yet been independently corroborated or actively validated. **Technical impact:** if exploited, this finding could allow compromise of the web application, the data it handles, or its users.

Remediation: See detailed finding above.

Cross Site Scripting (Reflected) (10.10.10.5:80)

Business impact: 10.10.10.5 is treated as high-criticality (set by the analyst) in this assessment's scope. This finding is currently 'suspected', reported by a single tool (zap), and has not yet been independently corroborated or actively validated. **Technical impact:** if exploited, this finding could allow compromise of the web application, the data it handles, or its users.

Remediation: Encode all user-controllable output.

6. Assessment Limitations

• None recorded.

Assumptions:

• LLM reasoning mode: rules-engine.

• CVSS scores marked 'estimated' were derived from the source tool's severity band, not independently calculated.

Human approvals and outcomes:

• [approved] Human-approved check-mode validation of 'MS17-010: SMB RCE' — requested by analyst; decided by lead-analyst at 2026-11-02T01:57:13+00:00; executed by n/a; outcome: n/a

Assessment timestamps: created 2026-11-02T01:57:13+00:00; report generated at report time.

7. Tool Integration Status (Transparency Matrix)

Tool	Status	Executable now	Note
nmap	live	True	Subprocess execution with -oX; also imports Nmap XML. NSE restricted t
nessus	import-only	False	Imports .nessus (NessusClientData_v2) exports. Live API control needs
openvas	import-only	False	Imports Greenbone/OpenVAS XML reports (get_reports). Live control via
nikto	live	True	Subprocess execution with -Format json; also imports Nikto JSON.
zap	live	False	Live via ZAP REST API (ZAP_URL, ZAP_API_KEY): spider + passive, option
burp	import-only	False	Burp Suite issue-export XML import. Live scanning needs Burp Suite Pro

metasploit	live	False	Human-approved, lab-only. Executes only the analyst-named module in `c